Course Code: ITA1439 **Course Name: Ethical Hacking**

Slot: A

CO2 – ASSIGNMENT_2

Nature of Assignment: Individual **Duration: 1 Week** **Total Marks: 50**

Student Name: Ajmal Rahman A **Reg. No:** 192324094

CO2: Execute footprinting and social-engineering techniques such as DNS analysis, competitive intelligence gathering and attack simulations to collect information for identifying potential security risks.

Assignment Title: Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment

Scenario - Assessment Design Philosophy

The assignment is designed for high-performing cybersecurity students and emphasizes the evaluation of reconnaissance and information-gathering choices rather than the mechanical use of tools. Students are expected to formulate an information-gathering strategy, construct difficult test conditions, run footprinting against authorized targets, collect evidence, identify limitations, compare alternatives and defend engineering decisions. All work is performed only against authorized or lab-owned targets, and no attack is launched against live systems or real individuals.

The assessment follows: Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate.

Q1 – Evaluate and Engineer a Footprinting Strategy **8 Marks**

Problem Context – Multi-Source Open-Source Information Gathering

A security team is authorized to footprint an organization that owns the domain example- corp. example before a penetration test. Each engagement must gather information from WHOIS, DNS, search engines and public documents, organize it, and use it to understand the target's attack surface.

The team has found that relying on a single source produces an incomplete and sometimes misleading picture. A domain with a clean WHOIS record may still leak information through

DNS, and a quiet DNS footprint may still be exposed through public documents. The strategy must therefore combine several sources and judge their reliability rather than trusting one.

Assessment Challenge

Design a footprinting strategy that combines passive and active techniques (WHOIS, DNS records, search-engine operators and archived pages) and classify each technique as passive or active.

Collect information from an authorized domain using appropriate tools such as whois, nslookup and dig, and organize the findings by source.

Ensure that out-of-scope domains, personal data and unverified results are not treated the same as authorized, verified, in-scope findings.

Construct four contrasting targets: a well-protected domain; a domain that leaks information; a domain with misconfigured DNS; and a domain with a minimal public footprint.

For every target, predict what information will be found before collection and compare it with the actual result.

Record the sources queried and the records found, and identify cases where one source contradicts another.

Evaluate whether the chosen sources are reliable and whether any source produces misleading or outdated information.

Changed Condition: The scope grows from one domain to fifty subdomains and several third-party services. Evaluate the original strategy, modify it where necessary, and defend whether it remains suitable for large-scale authorized reconnaissance.

Evidence Expected: Footprinting strategy design, authorized test targets, collected-source records, prediction-versus-observation analysis, source-reliability analysis, scope analysis and a justified final strategy.

ANSWER – Q1: Footprinting Strategy

1. Authorization and scope

Authorized target: lab-corp.example (RFC 2606 reserved name, student-owned lab zone, written authorization ref LAB-AUTH-01). In scope: lab-corp.example and *.lab-corp.example.

Out of scope: any third-party domain reached through a CNAME/MX/NS (e.g. cloud-dns.example, mail-saas.example) unless separately authorized. Passive steps come first; active steps start only after scope is confirmed.

2. Technique classification (passive vs active)

Technique	Tool / command	Type	Why
WHOIS registration data	whois lab-corp.example	Passive	Queries the registry, not the target
Search-engine operators	site:, filetype:, intitle:, inurl:	Passive	Uses the engine's index only
Archived pages	web.archive.org / cache	Passive	No packet reaches the target
Public-document metadata	exiftool on downloaded PDF/DOCX	Passive	Files already published
DNS A/MX/NS/TXT	dig / nslookup	Active	Queries target's authoritative servers
Zone transfer (AXFR)	dig axfr	Active	Only if explicitly authorized
Subdomain wordlist	dig in a loop	Active	Generates traffic on target DNS

3. Collection record and trust labelling

```
whois lab-corp.example                      > raw/whois.txt
dig +noall +answer lab-corp.example A MX NS TXT > raw/dns.txt
nslookup -type=NS lab-corp.example           >> raw/dns.txt
site:lab-corp.example filetype:pdf           (search, results -> raw/search.txt)
Archive snapshot list for lab-corp.example   > raw/archive.txt
```

Each finding is stored as: {source, query, value, time, scope = IN/OUT/PII, status = VERIFIED/UNVERIFIED}. Rules: (a) OUT items are logged but never expanded or reported as findings; (b) PII (employee names, personal emails) is stored separately, minimised and not used for further queries; (c) a finding becomes VERIFIED only when a second independent source or a direct query confirms it.

4. Four contrasting targets: prediction vs observation

Target	Predicted before collection	Observed	Match?
T1 Well-protected (secure.lab-corp.example)	WHOIS privacy on; only A, MX, NS; no TXT; AXFR refused	A, MX, NS found; AXFR refused; an SPF TXT record also present	Partly (TXT missed)
T2 Leaking (leak.lab-corp.example)	Dev/staging names in search and archive; contact email in WHOIS	filetype:pdf exposed author usernames and an internal path; archive showed an old /admin page; WHOIS showed registrant email	Yes
T3 Misconfigured DNS (misc.lab-corp.example)	AXFR permitted; internal hosts visible	AXFR returned 14 records incl. 10.0.x.x hosts	Yes
T4 Minimal footprint (min.lab-corp.example)	Only A and NS; nothing in search	A and NS found, plus a wildcard *.min record so any name resolves	Partly (wildcard missed)

5. Source contradictions and reliability

- WHOIS lists name server ns1.old-host.example but dig NS returns ns1.lab-corp.example → WHOIS is stale; DNS is trusted.
- Search cache mentions portal.lab-corp.example but dig returns NXDOMAIN → host decommissioned; marked UNVERIFIED/stale.

- Archive shows an older IP for www than the current A record → archive reflects the past, not the present.

Source	Reliability	Failure mode
Direct dig to authoritative NS	High	Wildcards inflate host count; split-horizon hides internal view
WHOIS	Medium	Privacy redaction, outdated NS/contacts
Search engine	Medium-Low	Cached/outdated pages, namesake domains
Archive	Low for "current" state	Historic data only

6. Changed condition: 50 subdomains + third-party services

Evaluation: the passive→active order and the tagging model still hold, but one-host-at-a-time manual commands do not scale (50 hosts × 4 record types = 200 manual queries) and CNAMEs now point into third-party services that are out of scope. Modification: (1) enumerate subdomains passively first (certificate-transparency listings, archive, search) into one list; (2) resolve the list with a script in batch, rate-limited; (3) before any query, filter by suffix and check whether the CNAME/NS target is owned by the client – if not, record "third-party boundary" and stop; (4) de-duplicate and flag wildcard answers; (5) report per-source counts.

7. Justified final strategy

Passive collection → scope filter and de-duplication → batch active DNS on in-scope hosts only → cross-check contradictions → label VERIFIED/UNVERIFIED → report. This remains suitable for large authorized reconnaissance because cost grows with the number of hosts only in the final active step, and the scope gate prevents third-party leakage.

Q2 – Build a Reliable DNS Footprinting Workflow **7 Marks**

Problem Context – Conflicting and Misconfigured DNS Data

An authorized assessment must map a target's DNS by retrieving A, MX, NS and TXT records and, only where explicitly permitted, attempting a zone transfer. Records may be inconsistent,

delegated to third parties, cached or misconfigured, so the workflow must interpret the results carefully rather than reporting them at face value.

Assessment Challenge

Develop a DNS footprinting workflow using dig and nslookup that retrieves A, MX, NS and TXT records, and attempts a zone transfer only where authorized.

Evaluate how split-horizon DNS, delegation and caching change the information visible to an external tester.

Construct at least six contrasting DNS cases, including a correctly secured server, a server that allows zone transfer, and a server with stale records.

For each case, predict the records exposed, run the workflow, trace what each query returns, and compare the result with the prediction.

Evaluate whether a misconfigured zone transfer meaningfully changes the attacker's knowledge and the resulting risk.

Introduce a countermeasure such as restricting transfers or using TSIG, and redesign the analysis to show the reduced exposure.

Evidence should include the DNS workflow, record analysis, authorized test cases, prediction-versus-observation comparisons, zone-transfer risk evaluation and the countermeasure redesign.

Evidence Expected: DNS workflow, record analysis, authorized test cases, prediction-versus-observation, zone-transfer risk evaluation and countermeasure redesign.

ANSWER – Q2: DNS Footprinting Workflow

1. Workflow (dig / nslookup)

```
# for each authorized zone Z and its name servers
dig +short NS Z                                # 1 delegation
for t in A MX NS TXT; do dig +noall +answer Z $t; done   # 2 records via resolver
for ns in $(dig +short NS Z); do
  dig @$ns +norecurse +noall +answer Z SOA     # 3 ask authoritative directly
done
nslookup -type=MX Z                            # 4 cross-check with 2nd tool
# 5 ONLY if written authorization covers it:
dig @ns1.Z axfr Z
# 6 compare resolver answer vs authoritative answer; log differences
```

2. Effect of split-horizon, delegation and caching

- **Split-horizon:** An external tester sees only the external view; internal names/IPs for the same zone are hidden, so absence of a record is not proof it does not exist.
- **Delegation:** Records below a delegation point belong to another operator; the tester sees only NS records and must stop if that operator is not authorized.
- **Caching:** A recursive resolver may return an old answer until TTL expires, so answers must be confirmed against the authoritative server (+norecurse / +trace).

3. Six DNS cases: prediction vs observation

Case	Predicted exposure	Observed (lab zone, dig)	Match?
C1 Secured server	A, MX, NS, TXT; AXFR refused	A, MX, NS, TXT returned; AXFR: "Transfer failed" (REFUSED)	Yes
C2 AXFR allowed	Whole zone via one query	14 records incl. internal 10.0.0.x hosts and a backup mail host	Yes
C3 Stale records	Old record resolves	old.lab-corp.example A 192.0.2.77 resolves (TTL 86400) but host does not respond → stale	Partly (resolves ≠ alive)
C4 Split-horizon	External sees public IP only	External: 198.51.100.10; internal view (lab client): 10.0.0.5	Yes
C5 Delegated sub-zone	Only NS visible for cloud.lab-corp.example	NS → third-party servers; records beyond not queried (out of scope)	Yes
C6 Cached change	New IP returned immediately	Resolver returned old IP until TTL expired; authoritative returned new IP	No (cache)

Trace summary: for C2 one AXFR replaced ≈ 200 wordlist queries; for C6 the resolver and authoritative answers differed, proving that resolver-only collection can be misleading.

4. Does a misconfigured zone transfer change the risk?

Yes. It converts guesswork (brute-forcing 200 names) into a complete map: all hostnames, internal IPs, mail and backup servers, naming convention and service layout. It is an information-disclosure weakness (not direct compromise) but it speeds up every later attack phase, so its risk rating is High.

5. Countermeasure and redesigned analysis

```
zone "lab-corp.example" {
    type master;
    allow-transfer { key "xfer-key"; };     # TSIG key only
};
key "xfer-key" { algorithm hmac-sha256; secret "<redacted>"; };
```

Measure (case C2)	Before	After (allow-transfer + TSIG)
AXFR from unauthorised host	14 records returned	REFUSED / NOTAUTH, 0 records
Records an outsider can learn	14 (incl. 5 internal)	≈ 5 public (A, MX, NS, TXT)
Queries needed to map zone	1	≈ 200 (brute force, noisy)

Q3 - Create a Competitive-Intelligence Awareness Utility **7 Marks**

Problem Context – Public Information and Human-Risk Exposure

A department is building a repeatable workflow that collects public business information about an authorized organization from job advertisements, annual reports, press releases and public profiles, and assesses how that information could support social-engineering attacks such as phishing, vishing, pretexting and tailgating, so that awareness and countermeasures can be designed. No social-engineering attack is performed against real people.

Your Challenge

Design documented steps for each public source and record where each item came from, using search-engine operators such as site, filetype: and intitle.

Map each collected item to the social-engineering technique it could enable (phishing, vishing, pretexting or tailgating) and the indicator a target should notice.

Create test organizations containing rich, sparse and misleading public information.

Predict the information and the human-risk level expected from each source before collection.

Evaluate whether the collected information meaningfully increases social-engineering risk and which source is the most dangerous.

Add two new sources or two new awareness countermeasures without restructuring the whole workflow, and evaluate the effect.

Record the sources queried, the items found and the countermeasures recommended.

Inquiry

Design and implement a modular competitive-intelligence and awareness workflow using documented sources and operators, and evaluate the human attack surface of an authorized organization.

Evidence should include the workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation and recommended countermeasures.

Evidence Expected: Workflow architecture, source operators, item-to-technique mapping, test organizations, prediction-versus-observation, risk evaluation and recommended countermeasures.

ANSWER – Q3: Competitive-Intelligence Awareness Utility

1. Workflow architecture (modular)

```
[Source adapters]  ads | reports | press | profiles | (new adapters plug in here)
        |
   [Collector]  -> raw items {source, operator, url, date, text}
        |
```

```
   [Normalizer] -> dedupe, tag source and date
        |
   [Mapper]     -> item -> technique (phishing/vishing/pretexting/tailgating) +
indicator
        |
   [Scorer]     -> risk Low/Med/High
        |
   [Reporter]   -> countermeasures + source log
```

2. Source operators (documented steps)

Source	Operator / step	Record kept
Job advertisements	site:careers.lab-corp.example intitle:"hiring" OR intitle:"engineer"	URL, date, tools/versions named
Annual reports	site:lab-corp.example filetype:pdf "annual report"	URL, names/roles, locations
Press releases	site:lab-corp.example intitle:"press release"	URL, partners, events
Public profiles	site:linkedin.com/company "lab-corp" (company page only)	Counts and role titles; no personal data stored

3. Item → technique mapping and indicator

Collected item	Technique enabled	Indicator the target should notice
Job ad lists exact VPN/mail products	Pretexting / phishing (fake vendor update)	Unexpected "update" for a tool, link to a non-company domain
Report names executives and finance head	Vishing / pretexting (executive impersonation)	Urgent payment request that skips normal approval
Press release names a new partner	Phishing (spoofed partner invoice)	Invoice from new address or look-alike domain
Report lists office address, photos of badges	Tailgating	Unknown person without badge following staff in
Email format firstname.lastname@	Phishing (target list building)	Mail addressed to many staff with the same lure

4. Test organizations: prediction vs observation (lab dataset)

Org	Predicted items / risk	Observed items / risk	Note
Org-A rich	40 / High	46 / High	Ads and profiles gave more items than expected
Org-B sparse	8 / Low	9 / Low	Matches
Org-C misleading	15 / Medium	12 items, 5 invalid / Low	Outdated ads and a namesake company's press release inflated the count

5. Risk evaluation

Public information does increase social-engineering risk: in Org-A the 46 items mapped to all four techniques. The most dangerous source is public profiles/organization data combined with job ads, because together they give names, roles, tool names and email format – everything needed for a convincing, personalised phishing or pretexting message. Misleading data (Org-C) lowers real risk but wastes analyst effort, so each item carries a date and source.

6. Extension without restructuring

Two new source adapters (archived careers pages, conference-talk slides) were added as new files calling the same Collector/Normalizer interface; no existing module changed. Two new countermeasures were added in the Reporter table: (1) remove exact product versions from job ads; (2) mandatory call-back verification for payment or access requests. Effect in Org-A: High-risk items 12 → 7 after the two countermeasures.

7. Recorded output (Org-A)

Source	Items found	Countermeasure recommended
Job ads	14	Generalise tool names; no versions
Annual reports	9	Limit org-chart detail; staff briefing on CEO fraud
Press releases	8	Partner-invoice verification rule
Profiles	15	Social-media policy; report suspicious contacts

Q4 – Design a Reconnaissance Data-Validation Mechanism **6 Marks**

Problem Context – High-Stakes Reconnaissance Data Quality

A reconnaissance data-collection process receives results that may be incomplete, outdated, duplicated or out of scope. Acting on poor-quality data wastes effort and can breach the agreed scope, so each item must be validated before it is used.

Your Challenge

Develop a validation mechanism that checks each collected item for scope, freshness, duplication and source reliability.

Distinguish a recoverable item (one that needs a re-query or confirmation) from an item that must be rejected (out of scope or unverifiable).

Construct at least five test sequences, including all-valid, out-of-scope, stale and duplicated data.

Predict how many items pass, fail or need re-checking before running the validation.

Evaluate whether the order of the validation checks affects effort and accuracy.

Redesign the validation order to reduce unnecessary checks while still keeping out-of-scope data out.

Scalability Inquiry

Predict and analyse the validation outcomes and the effort required as the volume of collected data grows from one target to fifty targets.

Evidence should include the validation design, adversarial reconnaissance inputs, pass/fail/re-check analysis, ordering evaluation and the justified redesign.

Evidence Expected: Validation design, adversarial reconnaissance sequences, pass/fail/re-check analysis, ordering evaluation and a justified redesign.

ANSWER – Q4: Reconnaissance Data-Validation Mechanism

1. Validation design

Each item {host, age_days, source, reliability} passes four checks: scope (host ends with .lab-corp.example), duplication (host already accepted), freshness (age ≤ 30 days) and source reliability (score ≥ 0.5). Outcomes: PASS; RECHECK (recoverable: stale, or low-reliability source → re-query/confirm); REJECT (not recoverable: out of scope, duplicate, or unverifiable source with score 0).

```
def validate(item, seen, order):
    for check in order:
        if check == "scope"  and not item["host"].endswith(".lab-corp.example"): return
"reject"
        if check == "dup"    and item["host"] in seen:                           return
"reject"
        if check == "fresh"  and item["age"] > 30:                               return
"recheck"
        if check == "rel":
            if item["rel"] == 0.0: return "reject"
            if item["rel"] <  0.5: return "recheck"
    seen.add(item["host"]); return "pass"
```

2. Five test sequences (10 items each): prediction vs observation

Sequence	Predicted pass/recheck/reject	Observed pass/recheck/reject	Match?
S1 all valid	10 / 0 / 0	10 / 0 / 0	Yes
S2 out-of-scope (5 of 10)	5 / 0 / 5	5 / 0 / 5	Yes
S3 stale (6 of 10)	4 / 6 / 0	4 / 6 / 0	Yes
S4 duplicated (4 unique hosts)	4 / 0 / 6	4 / 0 / 6	Yes
S5 mixed	4 / 3 / 3	4 / 2 / 4	No – an item from an unknown source (score 0) is unverifiable, so it is rejected, not rechecked

3. Does the order of checks matter?

Results (pass/recheck/reject) are almost unaffected, but effort is. Cost units: scope = 1, duplicate = 1, freshness = 1, reliability = 3 (it needs a source lookup). Original order: reliability → freshness → duplicate → scope.

Sequence	Original order cost	Redesigned order cost	Saving
S1	60	60	0
S2	60	35	25
S3	48	42	6
S4	54	36	18
S5	51	43	8
Total	273	216	57 (20.9 %)

4. Redesigned order (justified)

scope → duplicate → freshness → reliability. Cheapest and most decisive checks go first; the most expensive check runs last and only on items that can still be accepted. Scope is first so out-of-scope data is rejected before any lookup touches it, which keeps out-of-scope data out. In S2 the original order ran 5 reliability checks (15 units) on out-of-scope items; the redesign runs none.

5. Scalability: 1 → 10 → 50 targets (20 items per target, seeded random mix)

Targets	Items	Original cost / recheck	Redesigned cost / recheck	Passed
1	20	98 / 8	81 / 5	9 / 9
10	200	948 / 94	890 / 78	82 / 82
50	1000	4836 / 434	4416 / 333	447 / 447

Effort grows linearly with volume (≈ 97 → 88 cost units per target) because duplicate checks use a hash set (O(1)). The accepted set is identical in both versions; the redesign only reduces cost and the re-query queue (−23 % at 50 targets).

Q5 – Evaluate Footprinting of a Hierarchical Organization **7 Marks**

Problem Context – Irregular Multi-Level Organizational Footprint

A target organization has a nested public footprint of a parent domain, subdomains, departments and third-party services. Footprinting must traverse this hierarchy level by level, recording each level and stopping cleanly at out-of-scope or terminal nodes.

Your Challenge

Represent the organization's public footprint as a hierarchy (domain, subdomains and services) that can be traversed systematically.

Develop a systematic traversal that records each level and stops at out-of-scope or terminal nodes using an explicit boundary condition.

Construct shallow, deeply nested and irregular footprints with branches of differing size.

Predict the number of nodes and the information expected before the traversal.

Evaluate how depth and branching affect the effort and completeness of the footprinting.

Include an empty branch or a node with no public data and evaluate whether the boundary condition handles it correctly.

Compare the systematic traversal conceptually with an ad-hoc, unstructured approach.

Test Your Design

Verify whether the traversal correctly covers shallow, deep and irregular footprints without leaving the authorized scope.

Correctness Inquiry

Predict and verify the expected coverage, the boundary handling and the number of nodes visited.

Evidence should include the hierarchical footprint representation, the traversal design, the test structures, prediction-versus-observation and the boundary analysis.

Evidence Expected: Hierarchical footprint representation, traversal design, test structures, prediction-versus-observation, boundary analysis and a justified final design.

ANSWER – Q5: Hierarchical Organization Footprinting

1. Hierarchical representation

```
lab-corp.example                          (root, in scope)
 ├─ www.lab-corp.example                  (terminal)
 ├─ hr.lab-corp.example
 │    └─ portal.hr.lab-corp.example       (node with no public data)
 ├─ cloud.lab-corp.example -> saas.thirdparty.example   (OUT OF SCOPE: boundary)
 └─ dev.lab-corp.example
      └─ api.dev.lab-corp.example
```

Each node: {name, in_scope, has_data, children}. Terminal = no children; boundary = out of scope.

2. Traversal with explicit boundary condition

```
def traverse(root):
    stack, log = [root], []
```

```
    while stack:
        n = stack.pop()
        if not n.in_scope:                # BOUNDARY: record name, never query, never
expand
            log.append((n.name, "boundary")); continue
        log.append((n.name, "data" if n.has_data else "empty"))   # empty node still
recorded
        stack.extend(n.children)          # terminal node: children == [] -> loop ends
naturally
    return log
```

3. Test footprints: prediction vs observation

Footprint	Total nodes / depth / max branch	Predicted reachable	Visited (observed)	Recorded	Boundary stops	Empty nodes
Shallow	7 / 1 / 6	7	7	6	1	2
Deeply nested	8 / 6 / 2	6	6	5	1	2
Irregular	38 / 5 / 4	29	29	26	3	2

Predicted reachable = in-scope nodes whose ancestors are all in scope, plus the boundary nodes. In the deep case the nodes below the boundary (2 of 8) were correctly never visited; in the irregular case 9 of 38 nodes lay behind or at 3 boundaries and were skipped. Prediction equals observation in all three tests.

4. Depth, branching and the empty-branch case

- Effort equals the number of nodes visited, so wide/irregular trees cost more queries, while deep chains cost fewer queries but are strictly sequential (each level needs the previous result).
- Completeness depends on the boundary: a wrongly placed out-of-scope node can hide a whole subtree (deep case lost 2 nodes), so the boundary check must look at the node, not just its parent.
- Empty node: handled correctly – it is recorded as "empty", its children (if any) are still expanded, and it does not terminate the traversal or raise an error.

5. Systematic vs ad-hoc (same number of queries)

Footprint	Systematic: unique nodes recorded	Ad-hoc: unique nodes	Ad-hoc queries to out-of-scope nodes
Shallow	6 (+1 boundary, not queried)	6	1
Deep	5 (+1 boundary)	1	0
Irregular	26 (+3 boundaries)	9	1

The unstructured approach revisits nodes, misses branches and can query out-of-scope hosts; the systematic traversal gives full in-scope coverage with zero out-of-scope queries.

6. Correctness check

Expected coverage = 100 % of reachable in-scope nodes: achieved on all three footprints (7/7, 6/6, 29/29 nodes visited, 0 out-of-scope queries). Nodes visited matched the prediction exactly.

Q6 – Evaluate Footprinting Approaches Under Constraints **7 Marks**

Problem Context – Reconnaissance Under Time and Stealth Constraints

An authorized assessment must gather enough information while balancing speed, completeness and the risk of detection. Passive open-source collection and more active footprinting have different trade-offs, so the better approach depends on the scope and the constraints.

Your Challenge

Select two information-gathering approaches, for example passive open-source collection versus active DNS and service footprinting, and define what each produce.

Apply both approaches to the same authorized target.

Test at least four increasing scope sizes, including one at which one approach becomes impractical.

Record the number of queries or steps and the time taken where useful.

Evaluate redundant or repeated collection in each approach and identify where effort is wasted.

Determine whether the faster or the quieter approach is always the better engineering choice.

Defend a recommendation for a small-scope engagement and for a large-scope engagement.

Inquiry

The workflow is used both for teaching and for repeated real assessments; justify the chosen approach for each context.

Evidence should include the approach definitions, the two workflows, quantitative measures, the redundancy analysis and a defended recommendation.

Evidence Expected: Approach definitions, two workflows, quantitative measures, redundancy analysis and a defended recommendation.

ANSWER – Q6: Footprinting Approaches Under Constraints

1. Approach definitions

- **Approach P – passive open-source:** WHOIS, search operators, archive and certificate-transparency listings from 6 public sources; produces hostnames, contacts, historic data; no traffic to the target.
- **Approach A – active DNS/service:** dig of A, MX, NS, TXT, PTR for every host plus a 200-word subdomain wordlist; produces current, authoritative records; generates traffic on the target's DNS.

2. Workflows

```
P: for source in 6 sources: query page(s) -> merge -> dedupe -> list of hosts
A: for host in scope: dig A,MX,NS,TXT,PTR ; for word in wordlist(200): dig word.zone
```

3. Measurements at four scope sizes (model: P = 6 sources × ⌈n/100⌉ pages + 6 landing queries at 2 s each; A = 5n + 200 queries throttled to 5 q/s; assumed detection threshold 500 queries)

Hosts	P queries / time	P coverage	P redundant results	A queries / time	A coverage	A detectable?
1	12 / 24 s	100 %	75 %	205 / 41 s	100 %	No
10	12 / 24 s	90 %	64 %	250 / 50 s	100 %	No
50	12 / 24 s	98 %	71 %	450 / 90 s	100 %	No (near limit)
500	36 / 72 s	99 %	71 %	2700 / 540 s	100 %	Yes – impractical unthrottled

4. Redundancy

Passive: 64–75 % of returned results were repeats across sources (same host from several sources); fix by merging after each source and skipping already-known hosts. Active: NS, MX and TXT are zone-level and identical for every host, so 3(n−1) queries are wasted – 0 % at n = 1, 11 % at n = 10, 33 % at n = 50, 55 % at n = 500. Fix: query zone-level records once.

5. Is faster or quieter always better?

No. Passive is quieter and cheap but gave only 90–99 % coverage and can be stale (archive, WHOIS). Active is complete and current but loud, and at 500 hosts passes the detection threshold. The best choice depends on scope, authorization to generate traffic, and whether the defenders have been told about the test.

6. Recommendations

- **Small:** Small scope (1–10 hosts): active DNS – 205–250 queries, under a minute, complete, below the detection threshold; run a quick passive pass first to add historic names.
- **Large:** Large scope (50–500 hosts): passive first to discover hosts (12–36 queries), then active only on discovered in-scope hosts with zone-level records queried once and throttling; this cuts the active workload by up to 55 % of waste.

7. Teaching vs repeated real assessment

Teaching: Approach P – safe, repeatable, no live-system impact, easy to explain. Repeated real assessments: hybrid (P then A) because the same checks must be accurate, current and defensible each time.

DAY-4 DESIGN CHALLENGE

Q7 – Integrated Review: Diagnose, Redesign and Defend **8 Marks**

Select one workflow from Q1–Q6 that demonstrates a meaningful limitation, such as incomplete coverage, an unreliable source, excessive queries, weak validation or a risk of leaving scope, and improve it using evidence.

A. Diagnose the Limitation **2 Marks**

Identify the reconnaissance or logical bottleneck using evidence.

Determine whether the limitation is caused by source unreliability, redundant collection, poor ordering or a risk of going out of scope.

EVIDENCE EXPECTED

Identify the reconnaissance or logical bottleneck and support the diagnosis with evidence.

Pinpoint the underlying cause of the limitation, such as redundant collection, an unreliable source or poor ordering.

ANSWER – Q7A: Diagnose the Limitation

Selected workflow: Q4 validation mechanism, original check order (reliability → freshness → duplicate → scope).

- **Bottleneck (evidence):** In sequence S2 the original order ran the expensive reliability check on 5 out-of-scope items: 15 of 60 cost units (25 %) were spent on items that scope would reject immediately, and the check could involve a re-query toward an out-of-scope source, which is a scope risk.
- **Cause:** Poor ordering (expensive check first) combined with a risk of leaving scope. It is not source unreliability or redundant collection: the pass set was identical in both orders.

Supporting data

Sequence	Original cost	Reliability checks on items later rejected/rechecked

S2	60	5 (out-of-scope)
S4	54	6 (duplicates)

B. Establish Evaluation Criteria **1 Mark**

Define measurable criteria against which the original workflow will be judged.

Examples include coverage, the number of queries, source reliability, scope compliance and time.

Evidence Expected

A clearly defined set of measurable evaluation criteria, including coverage, number of queries, source reliability and scope compliance.

ANSWER – Q7B: Evaluation Criteria

Criterion	How measured	Target
Weighted effort	Cost units (scope 1, dup 1, fresh 1, reliability 3), 5 sequences + 50-target run	Lower than original
Scope compliance	Reliability/re-query checks run on out-of-scope items	0
Accuracy	Accepted (PASS) set identical to original	100 % same
Re-check queue	Number of RECHECK items	Not larger

C. Propose and Implement a Redesign **2 Marks**

Modify the original workflow to address the diagnosed limitation.

Provide the design logic or the ordered steps before implementation.

Identify any trade-off introduced by the redesign.

Evidence Expected

A redesigned workflow supported by design logic or ordered steps, demonstrating how the diagnosed limitation is addressed and identifying the trade-offs introduced.

ANSWER – Q7C: Redesign

Design logic / ordered steps

```
1. scope  : reject if host not under .lab-corp.example        (cost 1, decisive)
```

```
2. dup    : reject if host already accepted                    (cost 1, hash lookup)
3. fresh  : recheck if age > 30 days                           (cost 1)
4. rel    : reject if score 0, recheck if score < 0.5          (cost 3, last)
5. pass   : add host to accepted set
```

Trade-offs

- More cheap checks run on stale data (S3: 34 checks vs 28), although total cost is lower.
- A duplicate of an already-accepted host is rejected before freshness/reliability, so a later copy that is fresher or more reliable is discarded (reject count 119 → 220 at 50 targets, recheck 434 → 333). Mitigation: keep the highest-reliability copy.

D. Validate and Compare **2 Marks**

Use equivalent test conditions for the original and the redesigned workflow.

Collect quantitative evidence and determine whether the redesign actually improves the selected criterion.

Evidence Expected

A quantitative comparison of the original and redesigned workflows under equivalent conditions, using measurable criteria to verify the effectiveness of the redesign.

ANSWER – Q7D: Validate and Compare (identical test data, seeded)

Measure	Original	Redesigned	Change
Total cost, S1–S5	273	216	−20.9 %
S2 reliability checks on out-of-scope items	5	0	−100 %
50-target cost (1000 items)	4836	4416	−8.7 %
50-target RECHECK queue	434	333	−23.3 %
50-target accepted items	447	447	identical

Conclusion: the redesign improved the selected criteria (effort, scope compliance, re-check workload) without changing which items are accepted.

E. Defend the Final Engineering Judgment **1 Mark**

Evaluate whether the redesign met its objective.

Explain cases in which the original workflow may still be preferable.

Defend the final choice using experimental evidence rather than subjective statements.

Evidence Expected

A justified final engineering decision supported by experimental results, evaluating the redesign's effectiveness and identifying cases in which the original workflow remains preferable.

ANSWER – Q7E: Final Engineering Judgment

The redesign met its objective: 20.9 % lower effort on the five test sequences, 8.7 % lower at 50 targets, zero checks on out-of-scope items, and an identical accepted set. The original order is preferable in one case: when reliability scores are already cached (reliability cost = 1). Then the totals are 173 (original) vs 158 (redesigned) overall, but on stale-heavy data (S3) the original is cheaper (28 vs 34), because the redesign performs more checks before freshness can reject. Final decision: use scope → duplicate → freshness → reliability as default; use the original (freshness first) only for stale-heavy batches with cached reliability scores.

Note:

figures come from the lab simulation (sim.py, output in sim_output.txt); timing is supporting evidence only – the primary evidence is coverage, scope compliance and accepted-set equality.

MARK DISTRIBUTION

Question	Assessed Area	Marks
Q1	Footprinting strategy design and evaluation	8
Q2	DNS footprinting and analysis workflow	7
Q3	Competitive-intelligence and awareness utility	7
Q4	Reconnaissance data validation and recovery	6
Q5	Hierarchical organization footprinting	7
Q6	Footprinting approach comparison	7
Q7	Integrated diagnose–redesign–validate challenge	8
TOTAL		**50**

Submission Requirements

Submit:

Assignment report containing evidence for Q1–Q7.

Scripts or documented command sequences for all implemented workflows.

Student-designed authorized test targets and adversarial cases.

Raw collected data and tool outputs.

Prediction-versus-observation comparisons.

Tables/graphs wherever they strengthen the evaluation.

Source, query, item and scope counts where applicable.

Design representation or pseudocode for redesigned workflows.

Execution time may be reported as supporting evidence, but conclusions should not rely solely on timing; coverage, source reliability and scope compliance should form the primary evidence.

Assessment Verification / Viva

Students may be asked to explain and defend their source selection, footprinting methodology, DNS and open-source analysis, scope and authorization decisions, social-engineering-awareness reasoning, adversarial test design, measured results, redesign choices and final engineering judgments.

Overall Assessment Expectation

The assignment assesses the student's ability to evaluate information-gathering solutions under realistic, authorized conditions: Problem Interpretation → Prediction → Design → Collection → Adversarial Testing → Measurement → Analysis → Evaluation → Defence → Engineering Judgment.